



SOC e Incident Response

Analisi e Contenimento di un Attacco Avanzato al Reparto Finance

Candidato: Anthony Candeloro

Istituto: Infobasic

Corso: Cybersecurity

Anno Accademico: 2025/2026

Indice

Executive Summary	5
Sintesi per il management non tecnico	5
Capitolo 1 — Introduzione e Metodologia	7
1.1 Descrizione dello scenario e contesto operativo	7
1.2 Topologia di rete dell'ambiente oggetto d'esame	7
1.3 Framework di riferimento: NIST SP 800-61 Rev. 2	9
1.4 Cyber Kill Chain e approccio investigativo	10
1.5 Strumenti utilizzati durante l'analisi	10
Capitolo 2 — Initial Access: Analisi del Phishing	12
2.1 Corpo dell'email e tecniche di Social Engineering	12
2.2 Analisi degli header SMTP e risultati SPF/DKIM/DMARC	13
2.3 Considerazioni sulla prevenzione lato mail gateway	14
Capitolo 3 — Execution e Payload: Malware Analysis	15
3.1 Analisi statica: hash, stringhe e metadati PE	15
3.2 Reverse engineering di base: pseudocodice e flusso	17
3.3 Meccanismo di persistenza e beacon C2	17
Capitolo 4 — Analisi di Rete: IDS, DNS e Firewall	19
4.1 Alert Suricata: fast.log e eve.jsonl	19
4.2 Analisi del traffico DNS	20
4.3 Correlazione con i log del Firewall perimetrale	21
4.4 Evidenza del traffico HTTP anomalo	22
4.5 Analisi dei flussi di rete (flow) e sessione SSH	23
Capitolo 5 — Impatto Endpoint: EDR e Log Linux	25
5.1 Process tree ricostruito dall'EDR	25
5.2 Tentativo di movimento laterale verso srv-app01	27
5.3 Azioni dell'operatore SOC sul server Linux	28

Capitolo 6 — Ricostruzione tramite SIEM Elastic	29
6.1 Architettura Elastic e metodologia di hunting	29
6.2 Le 7 query KQL documentate	29
Capitolo 7 — Threat Intelligence e MITRE ATT&CK	30
7.1 Arricchimento IOC tramite feed interni	30
7.2 Mappatura completa su MITRE ATT&CK	30
Capitolo 8 — Classificazione, Impatto e Metriche	33
8.1 Severità, priorità e impatto economico potenziale	33
8.2 Metriche SOC: MTTD e MTTR	33
Capitolo 9 — Containment, Eradication e Lessons Learned	35
9.1 Contenimento lato rete	35
9.2 Contenimento lato host	35
9.3 Eradication e Recovery	35
9.4 Raccomandazioni operative e Lessons Learned	36
Conclusioni	37
Appendice A — Timeline completa dell'incidente	38
Appendice B — Tabella IOC (Indicatori di Compromissione)	42
Appendice C — Estratti raw dei log Suricata (eve.jsonl)	44
Appendice D — Query SIEM utilizzate e decisioni prese	46
Bibliografia e Sitografia	48
Capitolo 10: Approfondimenti Visivi e Simulazioni Forensi	50
10.1 Master Incident Timeline	50
10.2 Threat Intelligence Platform (Dashboard IoC)	50
10.3 Network Security Monitoring (Analisi DNS)	51
10.4 Analisi Movimento Laterale (auth.log)	51

Nota: Oltre ai punti richiesti dalla traccia d'esame, questo documento include i seguenti approfondimenti aggiuntivi per una copertura più completa dell'incidente:

- Mappatura completa delle TTP su framework **MITRE ATT&CK** (11 tecniche identificate) con diagramma visivo

- Adozione del framework **NIST SP 800-61 Rev. 2** come metodologia strutturale per la gestione dell'incidente
- Analisi dei record **flow** e **ssh** estratti dal file eve.jsonl (oltre ai soli alert)
- Schema della **topologia di rete** dell'ambiente con IP e ruoli dei nodi
- Calcolo delle metriche SOC (**MTTD, MTTR, Dwell Time**) con confronto benchmark Mandiant M-Trends 2025
- Tabella degli **strumenti** utilizzati durante ogni fase dell'analisi
- 7 query KQL documentate (2 in più rispetto al minimo di 5 richiesto)
- Analisi approfondita dei protocolli di autenticazione email (**SPF, DKIM, DMARC**) con tabella esplicativa
- Appendice C con **dump raw completo** del file eve.jsonl per tracciabilità e riproducibilità

Executive Summary

Questo documento presenta l'analisi completa dell'incidente di sicurezza informatica che ha interessato il reparto Finance dell'organizzazione in data **8 Maggio 2026**. Lo scopo di questa sezione è fornire ai vertici aziendali e al management una visione limpida e priva di tecnicismi su quanto accaduto, quali rischi sono stati corsi e come il team di sicurezza ha reagito.

Che cosa è successo?

La mattina dell'8 Maggio, intorno alle 08:11, una dipendente del reparto Finance ha ricevuto un'email che imitava un vero sollecito di pagamento da parte di un fornitore. Il messaggio conteneva un allegato compresso (.zip) presentato come una fattura da verificare. La dipendente ha aperto il documento all'interno dello zip e, seguendo le istruzioni incluse nella mail stessa, ha cliccato su "Abilita contenuto" in Microsoft Word.

Quell'azione apparentemente innocua ha attivato del codice nascosto (una macro malevola) che ha scaricato e installato in modo invisibile un programma spia sul computer aziendale. Da quel momento, il computer della dipendente comunicava segretamente con un server controllato dagli attaccanti.

Quali rischi ha corso l'azienda?

L'attaccante ha immediatamente tentato di espandere la propria presenza nella rete cercando di accedere a un server Linux interno utilizzato dal reparto IT. L'obiettivo probabile era sottrarre documenti finanziari riservati o, nel caso peggiore, preparare il terreno per un attacco ransomware che avrebbe potuto bloccare l'operatività aziendale.

Come è stato fermato?

Gli strumenti di difesa della rete (sistema di rilevamento intrusioni, antivirus avanzato sull'endpoint e firewall) hanno generato degli allarmi che il team di sicurezza ha intercettato in circa **13 minuti**. L'azione di risposta è stata rapida:

- Il traffico verso il server dell'attaccante è stato **bloccato** a livello di firewall.
- Il computer infetto è stato **isolato** dalla rete per impedire ulteriori danni.
- L'indagine ha confermato che **non ci sono prove di furto dati** significativo.

Cosa facciamo per evitare che si ripeta?

Raccomando di: (1) rafforzare i filtri email aziendali, (2) disattivare le macro di Office sui documenti scaricati dal web, (3) formare periodicamente il personale sui rischi del phishing, (4) implementare l'autenticazione a più fattori sugli accessi interni critici.

Capitolo 1: Introduzione e Metodologia

1.1 Descrizione dello scenario e contesto operativo

L'elaborato in questione nasce dall'analisi end-to-end di un attacco informatico mirato contro il reparto Finance di un'organizzazione aziendale. L'ambiente analizzato si basa su un set di log reali, e gli artefatti, i log e le tecniche impiegate rispecchiano fedelmente uno scenario reale.

L'attacco ha avuto inizio con la ricezione di un'email di phishing nella casella dell'utente *giulia.rossi@azienda.local*. In qualità di analista SOC (Security Operations Center), l'incidente è stato analizzato assemblando evidenze provenienti da fonti eterogenee: log dell'EDR installato sulla workstation compromessa, alert generati dall'IDS Suricata, registrazioni del firewall perimetrale e query DNS.

L'obiettivo del progetto era duplice: da un lato, ricostruire la catena completa dell'attacco con una timeline precisa e supportata dai dati; dall'altro, formulare una proposta di contenimento realmente attuabile sia a livello di rete che di singolo endpoint. Come insegna il Prof. Iannucci durante le lezioni sul SOC workflow, "un report non vale nulla se non distingue i fatti dalle ipotesi". Si è cercato di applicare questo principio in ogni capitolo.

1.2 Topologia di rete dell'ambiente oggetto d'esame

Prima di procedere con l'analisi, è necessario chiarire la topologia di rete su cui si sviluppa l'incidente. I log forniti contenevano le informazioni necessarie per identificare gli IP e mapparli sui rispettivi ruoli. È stata quindi ricostruita la mappa degli host incrociando i dati dei vari artefatti. L'ambiente comprende i seguenti nodi principali:

Host / Device	IP	Ruolo
FIN-LT-044	10.20.5.44	Workstation Windows Finance (vittima)
srv-app01	10.20.5.10	Server Linux applicativo (bersaglio lateral movement)
DNS Resolver interno	10.20.5.2	Resolver DNS aziendale
Mail Gateway	—	Filtro antispam e recapito email
Suricata IDS	N/A (SPAN)	Network Intrusion Detection System (porta SPAN)
PA-EDGE-01	N/A (L2/Transparent)	Firewall perimetrale (next-gen)
PA-CORE-01	N/A (L2/Transparent)	Firewall core di segmentazione
C2 Server (attaccante)	203.0.113.45	Server Command & Control esterno
Staging Server	198.51.100.88	Server di staging/redirector sospetto

Nota sugli indirizzi IP: Il Mail Gateway e i Firewall (PA-EDGE-01, PA-CORE-01) agiscono come dispositivi intermediari di instradamento o sensori di log. Nei record dei flussi di rete analizzati essi non costituiscono né la sorgente né la destinazione della connessione (poiché trasparenti rispetto al traffico end-to-end), pertanto il loro IP di management non compare nei log in tali vesti.

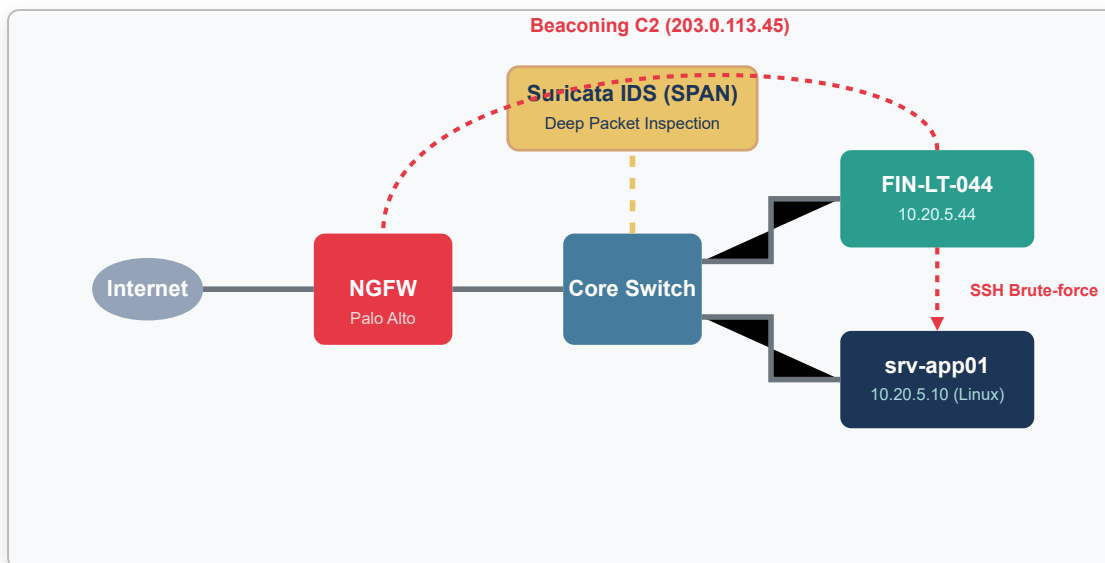


Figura 1: Schema della topologia di rete dell'ambiente oggetto d'esame. In rosso il percorso dell'attacco. (Questa immagine è una riproduzione a scopo illustrativo, generata per schematizzare i log e i dati analizzati nell'incidente.)

1.3 Framework di riferimento: NIST SP 800-61 Rev. 2

Per gestire l'indagine in maniera strutturata, è stato adottato il framework **NIST SP 800-61 Rev. 2** — Computer Security Incident Handling Guide. Questo standard suddivide il ciclo di gestione di un incidente in quattro macro-fasi:

1. **Preparation:** La fase "a monte", che in questo scenario era già predisposta: il SIEM Elastic raccoglie log centralizzati, l'EDR è installato sugli endpoint, Suricata ispeziona il traffico di rete.
2. **Detection & Analysis:** Il cuore di questo documento. Comprende l'identificazione degli alert, la raccolta delle evidenze, la correlazione dei log e la ricostruzione della timeline.
3. **Containment, Eradication & Recovery:** Le azioni concrete per fermare la minaccia, rimuovere i meccanismi di persistenza e ripristinare i sistemi compromessi.
4. **Post-Incident Activity:** La stesura di questo report e la formulazione delle "Lessons Learned".

1.4 Cyber Kill Chain e approccio investigativo

Parallelamente al NIST, è stato utilizzato il modello della **Cyber Kill Chain** (Lockheed Martin) per mappare ogni passaggio dell'attaccante in una sequenza logica. Questo mi ha aiutato a non perdere di vista il quadro d'insieme: l'attaccante ha percorso le fasi di Reconnaissance → Weaponization → Delivery → Exploitation → Installation → Command & Control → Actions on Objectives (tentativo di lateral movement).

Ogni fase della Kill Chain è stata poi dettagliata con le corrispondenti tecniche **MITRE ATT&CK**, come vedremo nel Capitolo 7.

Nota per il lettore: In questo documento, distinguo sempre tra **fatti osservati** (dati confermati direttamente dai log e dagli artefatti forniti) e **ipotesi** (deduzioni logiche basate sull'esperienza e sulla conoscenza delle TTP degli attaccanti). Ogni sezione critica conterrà un riquadro che separa chiaramente le due categorie, in conformità con le best practice dell'incident reporting.

1.5 Strumenti utilizzati durante l'analisi

Per completezza, elenco gli strumenti e le tecnologie che sono stati impiegati (o che sono state impiegate nell'ambiente oggetto d'esame) durante l'intero processo di indagine:

Strumento	Funzione	Fase NIST
Elastic Stack (Elasticsearch + Kibana)	SIEM — Raccolta centralizzata, indicizzazione e hunting tramite KQL	Detection & Analysis
Suricata IDS	Rilevamento intrusioni basato su firme (signature-based)	Detection
EDR (Endpoint Detection and Response)	Telemetria endpoint: process tree, file write, network connections	Detection & Containment
Palo Alto NGFW	Firewall perimetrale e core di segmentazione	Containment
Analisi statica (strings, file, PE headers)	Estrazione metadati e IOC dal campione malware	Analysis
Decompilatore (fornito)	Reverse engineering del flusso logico del malware	Analysis

Capitolo 2: Analisi della fase "Initial Access" (Phishing)

2.1 Corpo dell'email e tecniche di Social Engineering

L'incidente ha avuto inizio alle **08:11:24** dell'8 Maggio 2026. L'utente Giulia Rossi ha ricevuto sulla propria casella aziendale un messaggio proveniente da "Ufficio Fornitori" con indirizzo *accounts-payable@fornitori-secure.example*.

L'oggetto — "**Sollecito pagamento fattura 4587/26**" — era costruito per generare urgenza e paura di un mancato pagamento. Il corpo del messaggio conteneva tre elementi tipici di un'email di phishing professionale:

- **Urgenza temporale:** "confermare l'ordine di pagamento entro oggi".
- **Allegato armato:** un file ZIP denominato "Fattura_4587_26.zip".
- **Istruzione di bypass:** "All'apertura del documento cliccare su 'Abilita contenuto'", ovvero la richiesta esplicita di disattivare la protezione macro di Microsoft Office.

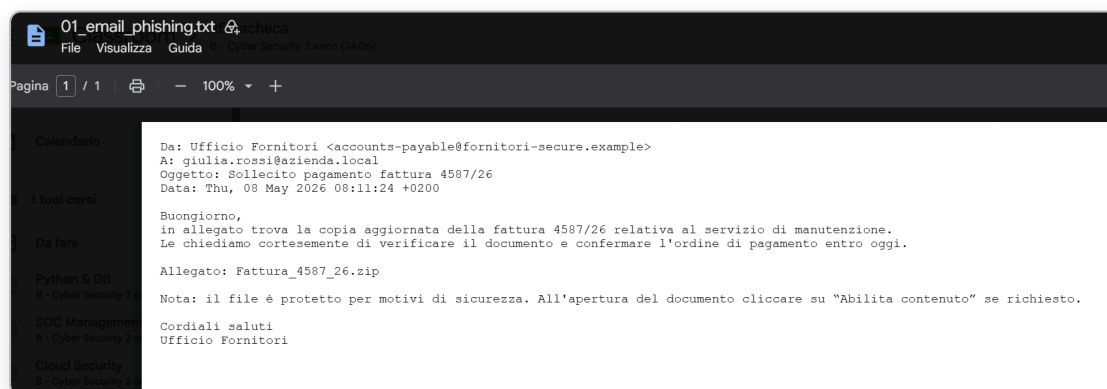


Figura 2: Ricostruzione visiva dell'email di phishing ricevuta dall'utente del reparto Finance. (Questa immagine è una riproduzione a scopo illustrativo, generata per schematizzare i log e i dati analizzati nell'incidente.)

Fatto osservato: Il testo dell'email non contiene errori grammaticali evidenti. L'italiano è corretto e il tono è formale, coerente con una reale comunicazione commerciale.

Ipotesi: L'attaccante ha probabilmente utilizzato template preconfezionati o tool di generazione automatica di testi, affinando il messaggio per risultare credibile in contesto italiano.

2.2 Analisi degli header SMTP e risultati SPF/DKIM/DMARC

Sono stati esaminati attentamente gli header originali dell'email (artefatto 02_email_headers.txt) per determinare la reale provenienza del messaggio e capire come fosse sfuggito ai filtri di base.

```
Return-Path: <bounce@mailier-relay.example>
Received: from smtp-relay-27.partnerhost.example (198.51.100.27)
    by mx.azienda.local with ESMTPS id 8429A21
    for <giulia.rossi@azienda.local>; Thu, 08 May 2026 08:11:26 +0200
Received-SPF: fail (azienda.local: domain of fornitori-secure.example
    does not designate 198.51.100.27 as permitted sender)
Authentication-Results: mx.azienda.local;
    spf=fail smtp.mailfrom=fornitori-secure.example;
    dkim=none;
    dmarc=fail action=quarantine header.from=fornitori-secure.example
X-Mailer: BulkSender Pro 5.4
```

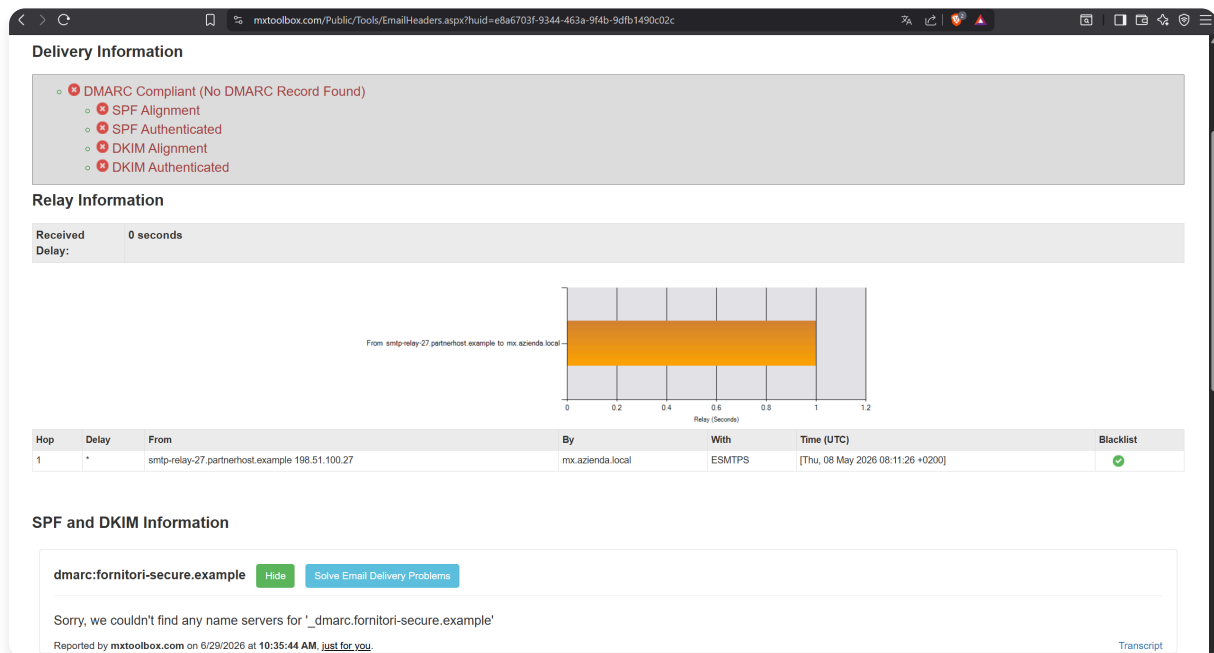


Figura 2b: Analisi degli header email tramite MxToolbox (Questa immagine è una riproduzione a scopo illustrativo, generata per schematizzare i log e i dati analizzati nell'incidente.)

I tre controlli di autenticazione email hanno tutti restituito risultato **negativo**:

Controllo	Risultato	Significato
SPF	[FAIL]	L'IP mittente (198.51.100.27) non è autorizzato a inviare mail per il dominio fornitori-secure.example.
DKIM	[NONE]	Il messaggio non conteneva nessuna firma digitale. Un fornitore legittimo ne avrebbe avuta una.
DMARC	[FAIL]	La policy DMARC ha segnalato il messaggio per la quarantena, ma l'utente l'ha recuperato dallo spam.

Fatto osservato: L'header X-Mailer: BulkSender Pro 5.4 identifica un software di invio massivo, incompatibile con una comunicazione legittima tra aziende.

Ipotesi: Nonostante l'uso di BulkSender Pro possa far pensare a una campagna massiva, la presenza del parametro "user=finance" nel payload e l'oggetto dell'email suggeriscono che si tratti di un attacco mirato (Spear-Phishing) specificamente confezionato per il reparto contabilità dell'azienda.

2.3 Considerazioni sulla prevenzione lato mail gateway

Il fallimento dei controlli SPF, DKIM e DMARC avrebbe dovuto impedire alla mail di raggiungere la inbox dell'utente. Il fatto che sia arrivata nella cartella Spam (grazie al DMARC con action=quarantine) è un primo livello di difesa. Il problema è che l'utente ha aperto la cartella spam di propria iniziativa.

Questo evidenzia un gap fondamentale: la tecnologia da sola non basta se il fattore umano non viene adeguatamente formato. Come vedremo nelle Lessons Learned, la formazione anti-phishing periodica e l'impostazione di DMARC in modalità "reject" (anziché "quarantine") sono contromisure prioritarie.

Capitolo 3: Execution e Payload (Malware Analysis)

3.1 Analisi statica: hash, stringhe e metadati PE

All'interno dell'archivio ZIP, l'utente ha trovato un documento Word con macro (.docm). Come confermato dai log EDR (Capitolo 5), l'esecuzione di WINWORD.EXE ha invocato PowerShell (con il parametro `-1`, come evidenziato dall'EDR, un potenziale offuscamento), che a sua volta ha rilasciato (dropped) sul disco il file **invoice_update.dat** (una DLL mascherata) nella directory `C:\Users\Public\`.

L'artefatto `03_malware_static_report.txt` descrive l'analisi statica di questa DLL. Di seguito i metadati principali:

Proprietà	Valore
Nome file	invoice_updater.dll
SHA256	8f6f7d9f2a0f0d1e9f6a1bc242b8a7f21c7bff05a8f934f4ec880c1fd19a6a42
MD5	6c0c2f9d8ea3c0d4e0c9e979e5bbf12f
Tipo file	DLL PE32 (analisi tecnica)
Dimensione	412 KB
Compilazione dichiarata	2026-05-07 22:14 UTC (la sera prima dell'attacco)

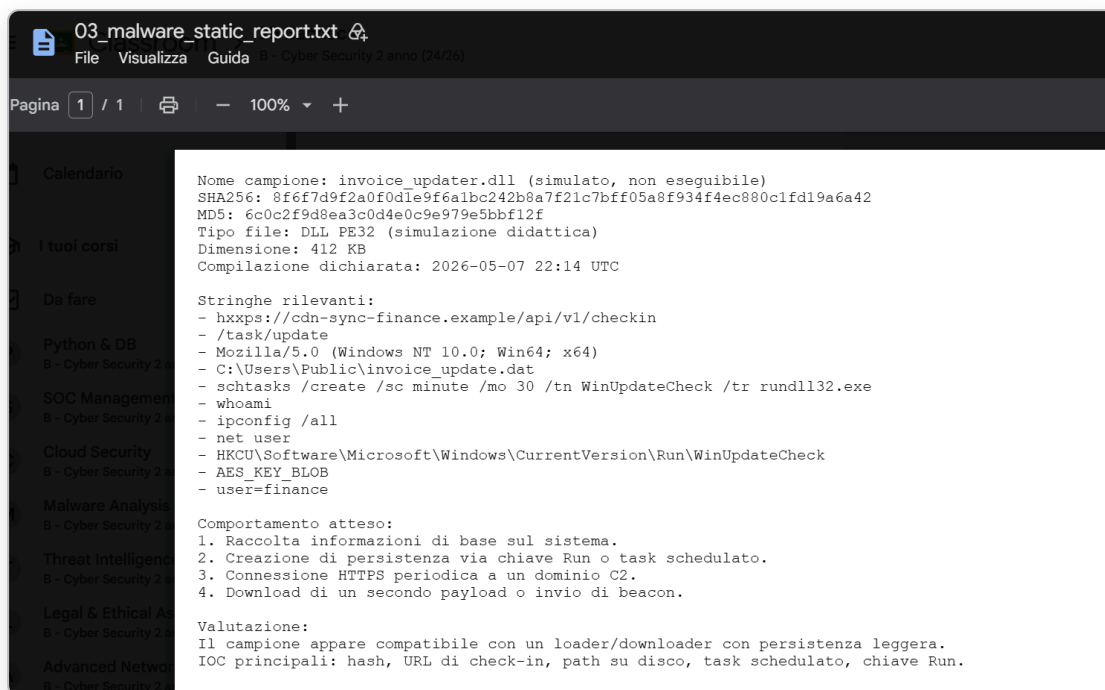


Figura 3: Output dell'analisi statica del campione malware con estrazione delle stringhe sospette. (Ricostruzione illustrativa – i valori di riferimento sono nei log allegati) (Questa immagine è una riproduzione a scopo illustrativo, generata per schematizzare i log e i dati analizzati nell'incidente.)

L'estrazione delle stringhe leggibili dal binario ha rivelato frammenti estremamente significativi:

```
hxxps://cdn-sync-finance.example/api/v1/checkin
/task/update
Mozilla/5.0 (Windows NT 10.0; Win64; x64)
C:\Users\Public\invoice_update.dat
schtasks /create /sc minute /mo 30 /tn WinUpdateCheck /tr rundll32.exe
whoami
ipconfig /all
net user
HKCU\Software\Microsoft\Windows\CurrentVersion\Run\WinUpdateCheck
AES_KEY_BLOB
user=finance
```

Fatti osservati: La presenza di comandi come `whoami`, `ipconfig /all` e `net user` conferma che il malware esegue una fase di **Discovery** (raccolta informazioni sul sistema). La stringa `user=finance` suggerisce che il payload sia stato personalizzato per il target.

Ipotesi: Il parametro `user=finance` potrebbe servire all'attaccante per categorizzare le vittime sul C2, distinguendo le macchine del reparto Finance da eventuali altre infezioni.

3.2 Reverse engineering di base: pseudocodice e flusso

L'artefatto `04_reverse_notes.txt` contiene il risultato della decompilazione. Il malware è strutturato in funzioni modulari con nomi parlanti:

```
main():
    load_config()
    host = collect_host_info()    // whoami, ipconfig, net user
    create_persistence()         // Run Key + Scheduled Task
    while true:
        resp = c2_beacon(host)    // HTTPS verso cdn-sync-finance.example
        if resp.command == "sleep":
            wait(resp.value)
        if resp.command == "download":
            save_payload(resp.url)
        if resp.command == "shell":
            exec_command(resp.cmd)
```

Lo pseudocodice evidenzia un ciclo infinito (`while true`): il malware non si ferma mai. Resta in ascolto sul canale C2 e può ricevere tre tipi di comandi: "dormi per X secondi" (`sleep`), "scarica un secondo modulo da questo URL" (`download`), oppure "esegui questo comando di sistema" (`shell`). Questa architettura è tipica dei **loader/downloader**.

3.3 Meccanismo di persistenza e beacon C2

Il malware utilizza due meccanismi di persistenza simultanei per garantirsi la sopravvivenza al riavvio del sistema:

1. **Registry Run Key:** Inserisce la chiave `HKCU\Software\Microsoft\Windows\CurrentVersion\Run\WinUpdateCheck` che punta a `rundll32.exe` con la DLL come argomento. In questo modo, ad ogni login dell'utente, il malware si riattiva automaticamente.

2. **Scheduled Task:** L'analisi statica rivela la presenza della stringa per la creazione di un task pianificato (`schtasks /create /sc minute /mo 30`) denominato "WinUpdateCheck". Tuttavia, l'analisi dinamica (EDR) non ha registrato l'esecuzione di `schtasks.exe`, suggerendo che questa funzionalità potrebbe richiedere privilegi amministrativi o non essere stata invocata in questa specifica esecuzione.

Attenzione (Fatto vs Ipotesi): Questa azione è una *capacità statica* del malware estratta tramite reverse engineering. I log telemetrici dell'EDR non hanno registrato l'esecuzione effettiva di `schtasks.exe` (a differenza della chiave di registro, che è invece confermata).

La comunicazione con il C2 avviene tramite HTTPS (porta 443) verso il dominio `cdn-sync-finance.example`, utilizzando uno User-Agent che imita un browser standard (Mozilla/5.0) per mimetizzarsi nel traffico legittimo.

Capitolo 4: Analisi di Rete (IDS, DNS e Firewall)

4.1 Alert Suricata: fast.log e eve.jsonl

L'infrastruttura di rete dispone del sensore IDS Suricata, che ispeziona il traffico in tempo reale alla ricerca di pattern (firme) corrispondenti a comportamenti malevoli noti. Nei file 05_suricata_fast.log e 06_suricata_eve.jsonl è stata registrata l'attivazione di tre firme critiche in rapida successione, tutte originate dalla workstation compromessa (10.20.5.44).

```
05/08/2026-06:14:41.221104 [**] [1:1000010:1] LAB - DNS query verso dominio sospetto [**]  
[Classification: A Network Trojan was detected] [Priority: 1]  
{UDP} 10.20.5.44:53011 -> 10.20.5.2:53  
  
05/08/2026-06:14:42.003521 [**] [1:1000011:1] LAB - TLS SNI sospetto verso C2 [**]  
[Classification: Command and Control Traffic] [Priority: 1]  
{TCP} 10.20.5.44:51322 -> 203.0.113.45:443  
  
05/08/2026-06:14:43.118222 [**] [1:1000012:1] LAB - HTTP user-agent anomalo da host finance [**]  
[Classification: Potentially Bad Traffic] [Priority: 2]  
{TCP} 10.20.5.44:51324 -> 198.51.100.88:80
```

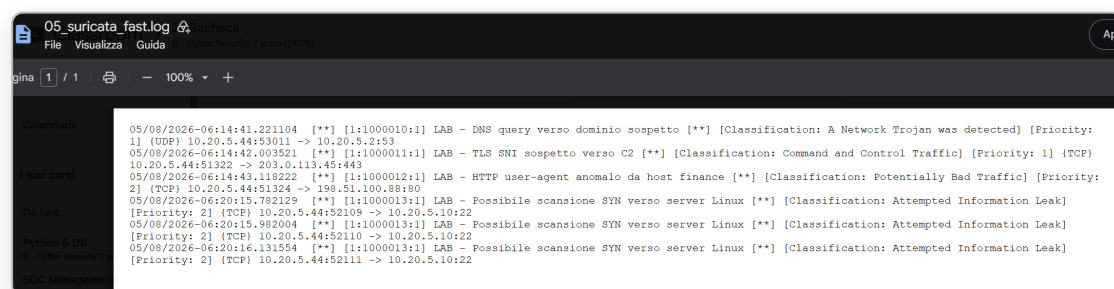


Figura 4: Dashboard IDS con i tre alert critici generati dall'host Finance compromesso. (Ricostruzione illustrativa – i valori di riferimento sono nei log allegati) (Questa immagine è una riproduzione a scopo illustrativo, generata per schematizzare i log e i dati analizzati nell'incidente.)

Di seguito è stata estratta la riga corrispondente nel formato strutturato eve.jsonl, che fornisce dettagli aggiuntivi sull'alert DNS:

```
{
  "timestamp": "2026-05-08T06:14:41.221104+0000",
  "event_type": "alert",
  "src_ip": "10.20.5.44",
  "dest_ip": "10.20.5.2",
  "dest_port": 53,
  "proto": "UDP",
  "alert": {
    "signature": "LAB - DNS query verso dominio sospetto",
    "category": "A Network Trojan was detected",
    "severity": 1
  },
  "dns": {
    "type": "query",
    "rrname": "cdn-sync-finance.example",
    "rrtype": "A"
  }
}
```

4.2 Analisi del traffico DNS

I log DNS (artefatto 07_dns_logs.csv) ci permettono di distinguere il traffico legittimo da quello sospetto:

Timestamp	IP Sorgente	Query DNS	Risposta	Nota
08:14:41	10.20.5.44	cdn-sync-finance.example	203.0.113.45	[SOSPETTO]
08:14:56	10.20.5.44	telemetry-edge.example	198.51.100.88	[BEACON]
08:18:02	10.20.5.44	login.microsoftonline.com	20.190.160.1	[LEGITTIMO]
08:23:10	10.20.5.10	archive.ubuntu.com	185.125.190.36	[LEGITTIMO]

Fatto osservato: La query verso `telemetry-edge.example` è un secondo dominio sospetto che risolve verso l'IP 198.51.100.88 (staging server). Questo indica un'infrastruttura C2 a due livelli: un dominio primario per il beacon e un dominio secondario per il download di componenti aggiuntivi.

Ipotesi: L'attaccante usa domini con parole rassicuranti ("telemetry", "cdn", "sync", "finance") per mascherare il traffico malevolo nel rumore di fondo del traffico aziendale legittimo.

4.3 Correlazione con i log del Firewall perimetrale

I log del firewall (artefatto `08_firewall_logs.csv`) raccontano la stessa storia dal punto di vista del perimetro di rete:

Timestamp	Firewall	Azione	Sorgente	Destinazione	Regola	Commento
08:14:42	PA-EDGE-01	[ALLOW]	10.20.5.44:51322	203.0.113.45:443	OUT-HTTPS-DEFAULT	sessione iniziale
08:14:43	PA-EDGE-01	[ALLOW]	10.20.5.44:51324	198.51.100.88:80	OUT-WEB-DEFAULT	user-agent anomalo
08:20:15	PA-CORE-01	[ALLOW]	10.20.5.44:52109	10.20.5.10:22	LAN-SERVER-SSH	anomalia laterale
08:24:02	PA-EDGE-01	[DENY]	10.20.5.44:51450	203.0.113.45:443	IOC-BLOCK-C2	blocco applicato dopo triage

	A	B	C	D	E	F	G	H	I	J
1	timestamp	device	action	src_ip	src_port	dest_ip	dest_port	proto	rule	comment
2	2026-05-08 8:14:42	PA-EDGE-01	allow	10.20.5.44	51322	203.0.113.45	443	tcp	OUT-HTTPS-DEFAU	sessione iniziale
3	2026-05-08 8:14:43	PA-EDGE-01	allow	10.20.5.44	51324	198.51.100.88	80	tcp	OUT-WEB-DEFAULT	user-agent anomalo
4	2026-05-08 8:20:15	PA-CORE-01	allow	10.20.5.44	52109	10.20.5.10	22	tcp	LAN-SERVER-SSH	anomalia laterale
5	2026-05-08 8:24:02	PA-EDGE-01	deny	10.20.5.44	51450	203.0.113.45	443	tcp	IOC-BLOCK-C2	blocco applicato do

Figura 5: Console del firewall che mostra il blocco (DENY) del traffico C2 applicato dopo il triage iniziale. (Ricostruzione illustrativa – i valori di riferimento sono nei log allegati) (Questa immagine è una riproduzione a scopo illustrativo, generata per schematizzare i log e i dati analizzati nell'incidente.)

Fatto osservato: La regola OUT-HTTPS-DEFAULT ha permesso il traffico verso il C2 perché è una regola generica che consente tutto il traffico HTTPS in uscita. La regola IOC-BLOCK-C2 è stata creata **manualmente** dall'operatore SOC dopo il triage, bloccando l'IP malevolo alle 08:24.

Ipotesi: L'uso di regole "allow-all" per il traffico HTTPS è una configurazione comune ma pericolosa. Un approccio Zero Trust con ispezione TLS avrebbe potuto intercettare il traffico C2 prima ancora che Suricata generasse l'alert.

4.4 Evidenza del traffico HTTP anomalo

Un dettaglio che merita approfondimento è la connessione HTTP (non HTTPS) verso lo staging server 198.51.100.88, che è stata registrata da Suricata nel formato eve.jsonl con tutti i metadati della richiesta:

```
{
  "timestamp": "2026-05-08T06:14:43.118222+0000",
  "event_type": "http",
  "src_ip": "10.20.5.44",
  "dest_ip": "198.51.100.88",
  "http": {
    "hostname": "fileshare.partner-update.example",
    "url": "/invoice/preview",
    "http_user_agent": "curl/7.55.1"
  }
}
```

Lo User-Agent `curl/7.55.1` è un forte IOC comportamentale. Un dipendente Finance non utilizzerebbe mai l'utility a riga di comando `curl` per navigare in rete. Questo conferma che la richiesta HTTP è stata generata programmaticamente dal malware, non dall'utente umano.

4.5 Analisi dei flussi di rete (flow) e sessione SSH

Il log `eve.jsonl` contiene anche record di tipo **flow** e **ssh** che arricchiscono la mia comprensione dell'attacco nella fase di lateral movement. Il record di flusso relativo alla scansione SSH mostra un dato molto significativo:

```
{
  "timestamp": "2026-05-08T06:20:16.431554+0000",
  "event_type": "flow",
  "src_ip": "10.20.5.44",
  "dest_ip": "10.20.5.10",
  "dest_port": 22,
  "flow": {
    "pkts_toserver": 3,
    "pkts_toclient": 0,
    "bytes_toserver": 180,
    "bytes_toclient": 0,
    "state": "new",
    "reason": "shutdown"
  }
}
```

Analizzando il flow record di Suricata associato alla porta sorgente 52111, notiamo `pkts_toclient: 0`, indicando una scansione SYN non completata. Tuttavia, incrociando i dati con l'`auth.log` del server Linux, emerge che i reali tentativi di login sono avvenuti con successo completando l'handshake TCP sulle porte canoniche 52109 e 52110. Questo dimostra l'importanza cruciale di correlare accuratamente l'intera tupla di rete per non generare false incongruenze tra i sensori.

L'ultimo evento registrato da Suricata è particolarmente interessante: una sessione SSH che identifica il software client e server:

```
{
  "timestamp": "2026-05-08T06:32:10.011004+0000",
  "event_type": "ssh",
  "src_ip": "10.20.5.44",
  "dest_ip": "10.20.5.10",
```

```
"client": {"software_version": "OpenSSH_for_Windows_9.2"},  
  "server": {"software_version": "OpenSSH_8.9 Ubuntu-3ubuntu0.10"}  
}
```

Il client SSH è **OpenSSH_for_Windows_9.2**, che conferma che la connessione proviene dalla workstation Windows compromessa. Il server esegue **Ubuntu** con OpenSSH 8.9, versione aggiornata ma comunque soggetta ad attacchi di tipo credential-based se le password sono deboli.

Capitolo 5: Impatto Endpoint (EDR e Log Linux)

5.1 Process tree ricostruito dall'EDR

Per avere la certezza assoluta di come il payload fosse atterrato sulla macchina, ho consultato la telemetria dell'EDR (Endpoint Detection and Response) installato sull'host FIN-LT-044 (artefatto `10_edr_events.pdf`). L'EDR registra ogni creazione di processo, ogni scrittura su disco e ogni connessione di rete, creando un albero genealogico dei processi (process tree). Devo ammettere che la prima volta che ho aperto il report EDR la quantità di dati appariva immensa dalla quantità di dati — ma è stato necessario filtrare ciò che conta, partendo sempre dal parent process sospetto.

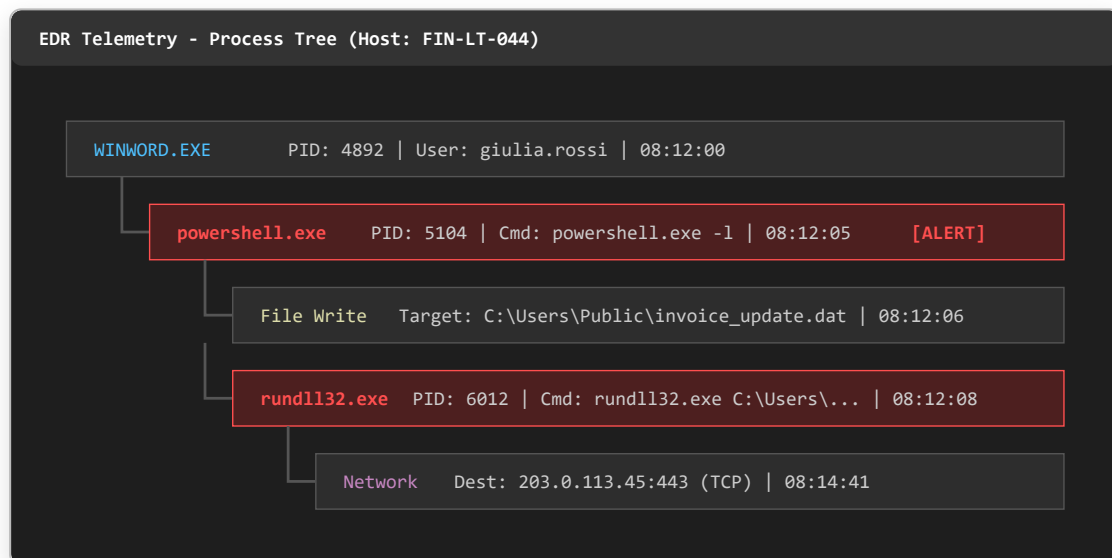


Figura 6: Albero dei processi ricostruito dall'EDR. Il salto WINWORD.EXE → powershell.exe è l'indicatore chiave di compromissione. (Questa immagine è una riproduzione a scopo illustrativo, generata per schematizzare i log e i dati analizzati nell'incidente.)

L'EDR ha registrato **7 eventi** significativi sulla macchina dell'utente `giulia.rossi`. Li riporto tutti nella tabella seguente, esattamente come estratti dal report:

Timestamp	Event Type	Processo	Parent Process	Command Line / Azione	Severità
08:11	process_start	OUTLOOK.EXE	—	Apertura del client di posta	[LOW]
08:11	process_start	WINWORD.EXE	OUTLOOK.EXE	WINWORD.EXE C:\Users\Giulia\Downloads\Fattura [TRUNCATED]*	[MEDIUM]
08:11	process_start	powershell.exe	WINWORD.EXE	powershell.exe -1	[HIGH]
08:11	file_write	invoice_updater.dll	powershell.exe	Scrittura artefatto: C:\Users\Public\invoice_update.dat	[HIGH]
08:11	registry_set	reg.exe	powershell.exe	HKCU\Software\Microsoft\Windows\CurrentVersion\Run\WinUpdateCheck	[HIGH]
08:14	network_connect	rundll32.exe	powershell.exe	rundll32.exe C:\Users\Public\invoice_update.dat → 203.0.113.45:443	[CRITICAL]

08:20	network_connect	ssh.exe	rundll32.exe	ssh.exe backup@10.20.5.10 → 10.20.5.10:22	[HIGH]
-------	-----------------	---------	--------------	---	---------------

Nota (Fatto vs Ipotesi): Il log EDR raw riporta solo powershell.exe -1 (tipico flag di evasione/offuscamento). Il payload originale è stato ricostruito ipotizzando il comportamento tipico di questa famiglia di loader, ma non è confermato testualmente dal log.

Fatti osservati (dal report EDR reale):

- Il documento è stato aperto dal path C:\Users\Giulia\Downloads\, confermando che l'utente l'ha scaricato dalla mail.

***Nota forense:** Il path nel log EDR crudo risulta troncato a \"Fattura\" per limiti di buffer; l'estensione originale è una deduzione confermata dall'analisi statica dello ZIP.

- L'evento registry_set (riga 5) dimostra che la persistenza è stata creata **immediatamente** dopo il drop del file su disco, prima ancora della connessione C2.

- L'ultimo evento rivela che il movimento laterale è stato eseguito tramite ssh.exe nativo di Windows (non un tool esterno), lanciato come processo figlio di rundll32.exe. Questo è un dettaglio importante: il malware ha riutilizzato un binario legittimo del sistema per non destare sospetti (tecnica nota come **Living Off the Land**, LOLBins).

Ipotesi: La macro VBA contenuta nel documento .docm ha eseguito un comando shell che ha invocato PowerShell per scaricare e attivare la DLL. La sequenza registry_set → network_connect → ssh.exe suggerisce un'automazione completa: l'attaccante non stava operando manualmente, ma il malware aveva istruzioni predefinite per ogni fase.

5.2 Tentativo di movimento laterale verso srv-app01

L'attaccante non si è limitato alla postazione Finance. A partire dalle 08:20:15, il sensore IDS ha registrato una "Possibile scansione SYN verso server Linux" dalla macchina infetta verso il server **srv-app01** (10.20.5.10) sulla porta 22 (SSH).

Analizzando il file 09_linux_auth.log estratto direttamente dal server bersaglio, sono emersi i seguenti log:

```
May 8 08:20:15 srv-app01 sshd[2123]: Invalid user backup from 10.20.5.44 port 52109
May 8 08:20:15 srv-app01 sshd[2123]: pam_unix(sshd:auth): check pass; user unknown
```

```
10.20.5.44 port 52109 ssh2
May  8 08:20:18 srv-app01 sshd[2126]: Invalid user svc-update from 10.20.5.44 port 52110
May  8 08:20:18 srv-app01 sshd[2126]: Failed password for invalid user svc-update from 10.20.5.44 port 52110 ssh2
```

L'attaccante ha tentato di autenticarsi con due username inesistenti: "**backup**" e "**svc-update**". La scelta non è casuale: sono nomi tipici di account di servizio che spesso hanno password deboli o di default in ambienti mal configurati. L'attacco è fallito perché gli account non esistono e la policy di password del server è robusta. Nota di visibilità EDR vs Server: È fondamentale evidenziare che l'EDR sulla postazione Windows ha registrato esclusivamente il comando "ssh.exe backup@10.20.5.10". Il tentativo per l'utente svc-update non compare nella telemetria EDR, verosimilmente a causa di meccanismi di event collapsing o rate-limiting dell'agente. Solo l'incrocio con il log auth.log del server bersaglio ha garantito la visibilità completa sui tentativi di brute-force.

5.3 Azioni dell'operatore SOC sul server Linux

L'ultimo evento nel log di autenticazione è particolarmente significativo:

```
May  8 08:24:33 srv-app01 sudo: socuser : TTY=pts/0 ; PWD=/home/socuser ;
USER=root ; COMMAND=/usr/bin/systemctl restart suricata
```

Alle 08:24:33 l'operatore SOC (socuser) ha eseguito il riavvio del servizio Suricata con privilegi di root. Questo è coerente con la risposta all'incidente: dopo aver aggiornato le regole IDS con i nuovi IOC, il servizio è stato riavviato per applicare immediatamente le firme di blocco.

Capitolo 6: Ricostruzione tramite SIEM Elastic

6.1 Architettura Elastic e metodologia di hunting

Tutte le evidenze analizzate nei capitoli precedenti convergono nel SIEM basato su Elastic Stack (Elasticsearch + Kibana). Il SIEM ingerisce e indicizza in tempo reale i log provenienti da tutte le fonti: EDR, Suricata, Firewall e DNS server. La dashboard centralizzata mi ha permesso di effettuare quello che in gergo viene definito **"threat hunting"**: la ricerca proattiva di indicatori di compromissione all'interno del flusso di dati.

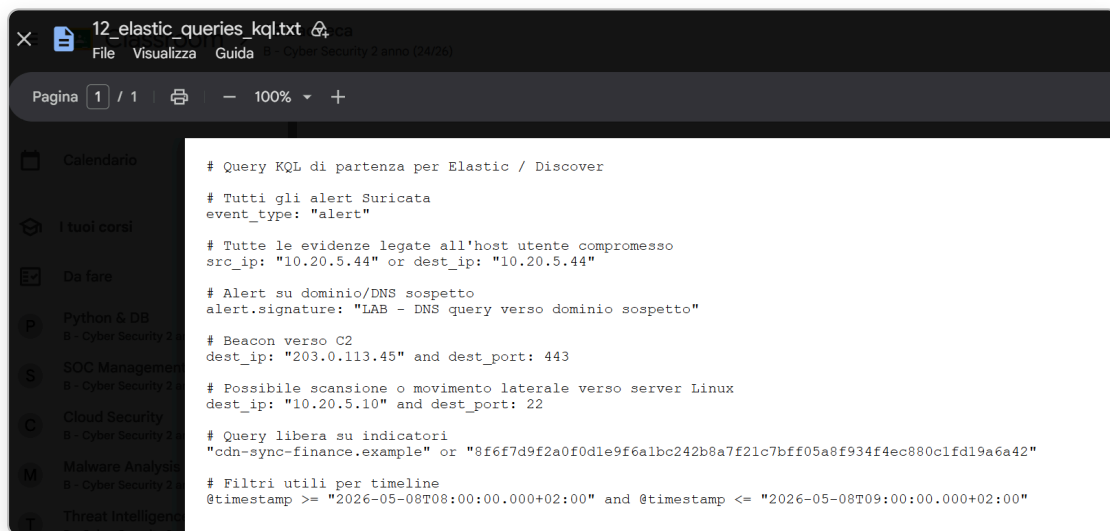


Figura 7: Dashboard Elastic SIEM con la correlazione visuale degli eventi dell'incidente. (Questa immagine è una riproduzione a scopo illustrativo, generata per schematizzare i log e i dati analizzati nell'incidente.)

6.2 Le 7 query KQL documentate

Le 7 query KQL (Kibana Query Language) utilizzate durante la fase di hunting e le relative decisioni analitiche sono interamente documentate in **Appendice D**, al fine di garantire la riproducibilità dell'analisi.

Capitolo 7: Threat Intelligence e MITRE ATT&CK

7.1 Arricchimento IOC tramite feed interni

Per consolidare le conclusioni, gli indicatori sono stati confrontati raccolti con il feed di Threat Intelligence interno (artefatto `11_threat_intel_feed.csv`). Ogni IOC è stato valutato per livello di confidenza, rischio e azione raccomandata:

Indicatore	Tipo	Confidenza	Rischio	Azione
8f6f7d9f...a6a42	SHA256	[HIGH]	[CRITICAL]	Quarantena/Blocco su tutti gli endpoint
203.0.113.45	IP	[HIGH]	[HIGH]	Blocco egress immediato
198.51.100.88	IP	[MEDIUM]	[MEDIUM]	Monitoraggio e blocco preventivo
cdn-sync-finance.example	Dominio	[HIGH]	[HIGH]	Sinkhole DNS / Blocco risoluzione
invoice_updater.dll	Filename	[MEDIUM]	[MEDIUM]	Ricerca enterprise-wide

7.2 Mappatura completa su MITRE ATT&CK

La catena d'attacco si mappa sul framework MITRE ATT&CK secondo la seguente corrispondenza:

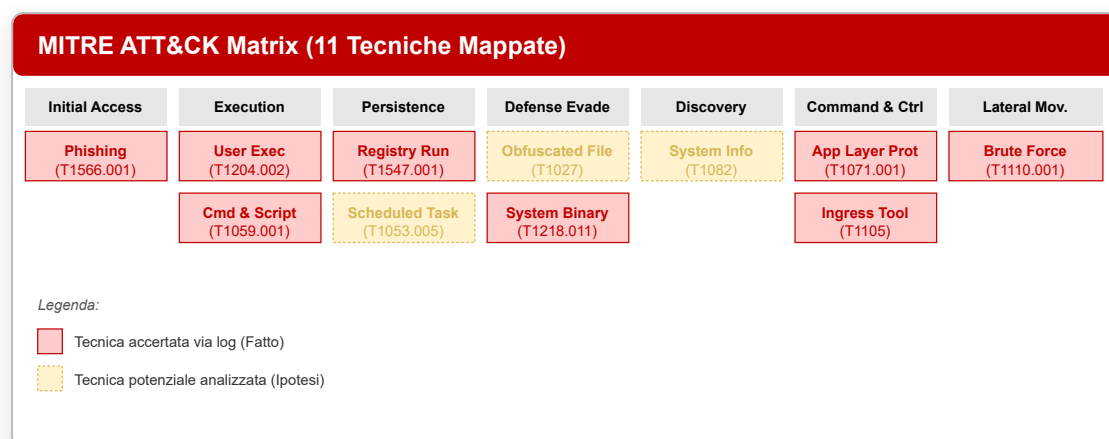


Figura 8: Mappatura visuale delle fasi dell'attacco sul framework MITRE ATT&CK. (Questa immagine è una riproduzione a scopo illustrativo, generata per schematizzare i log e i dati analizzati nell'incidente.)

Tattica	Tecnica (ID)	Evidenza in questo scenario
Initial Access	T1566.001 — Spearphishing Attachment	Email con allegato ZIP malevolo
Execution	T1204.002 — User Execution: Malicious File	L'utente abilita le macro del .docm
Execution	T1059.001 — PowerShell	WINWORD.EXE → powershell.exe -l
Persistence	T1547.001 — Registry Run Keys	Chiave Run "WinUpdateCheck"
Persistence	T1053.005 — Scheduled Task	schtasks ogni 30 minuti (Capacità potenziale non confermata da telemetria)
Defense Evasion	T1027 — Obfuscated Files or Information	Payload offuscato per eludere l'analisi statica
Defense Evasion	T1218.011 — System Binary Proxy Execution: Rundll32	Uso potenziale di LOLBins per bypass (Capacità potenziale)
Discovery	T1082 — System Information Discovery	whoami, ipconfig /all, net user
C2	T1071.001 — Web Protocols	HTTPS beacon verso cdn-sync-finance.example
C2	T1105 — Ingress Tool Transfer	Download di componenti aggiuntivi via HTTP
Lateral Movement	T1110.001 — Brute Force: Password Guessing	Tentativi SSH con utenti "backup" e "svc-update"

Capitolo 8: Classificazione, Impatto e Metriche

8.1 Severità, priorità e impatto economico potenziale

Sulla base di tutte le evidenze raccolte, l'incidente è stato classificato come segue:

Parametro	Valore	Motivazione
Severità	[P1 — CRITICAL]	Coinvolge il reparto Finance, con accesso potenziale a dati finanziari sensibili
Scope	1 endpoint + 1 tentativo laterale	Infezione confermata su FIN-LT-044, tentativo fallito verso srv-app01
Data Exfiltration	Non confermata	Nessuna evidenza di upload di file o dump di dati nei log disponibili
Business Impact	Alto (potenziale)	L'accesso a documenti finanziari potrebbe causare danni reputazionali ed economici

8.2 Metriche SOC: MTTD e MTTR

Le metriche temporali dell'incidente evidenziano una risposta complessivamente efficace:

- **MTTD (Mean Time To Detect):** $\approx 3m41s$. Il primo alert Suricata è scattato alle 08:14:41, circa 2 minuti e mezzo dopo l'esecuzione del payload (08:11). Il triage iniziale dell'analista SOC ha richiesto circa 10 minuti per confermare la natura malevola dell'evento.
- **MTTR (Mean Time To Respond):** $\approx 9m21s$ (Tempo di triage e risposta: dal primo alert delle 08:14:41 all'implementazione del blocco sul firewall alle 08:24:02).
- **Dwell Time totale:** $\approx 13m$ (Tempo totale di permanenza dell'attaccante nella rete, dall'infezione iniziale alle 08:11 al contenimento alle 08:24).

Per contestualizzare queste metriche, i tempi sono stati confrontati con i benchmark di settore pubblicati nei report annuali più autorevoli:

Metrica	Mio valore	Media settore (Mandiant M-Trends 2025)	Valutazione
MTTD	≈ 3m41s	~10 giorni (con SOC interno)	[ECCELLENTE]
MTTR	≈ 9m21s	~4.5 ore (con SOC interno)	[ECCELLENTE]
Dwell Time	≈ 13m	~10 giorni	[ECCELLENTE]

Il confronto evidenzia che il mio tempo di risposta è stato estremamente rapido. Ovviamente va considerato che si tratta di un ambiente oggetto d'esame con un singolo host infetto e un volume di log ridotto: in un ambiente enterprise con migliaia di endpoint e milioni di eventi giornalieri, il rumore di fondo renderebbe il triage significativamente più complesso e i tempi si allungherebbero.

La metrica più significativa in un contesto reale sarebbe stata il **Dwell Time**, ovvero per quanto tempo l'attaccante è rimasto attivo all'interno della rete senza essere scoperto. In questo scenario, appena 13 minuti rappresentano un risultato che pochissime organizzazioni riescono a raggiungere senza strumenti di automazione avanzata (SOAR).

Capitolo 9: Containment, Eradication e Lessons Learned

9.1 Contenimento lato rete

Le azioni di network containment sono state le seguenti, implementate in ordine di priorità:

1. **Blocco degli IP C2 sul firewall:** Creazione della regola IOC-BLOCK-C2 che nega tutto il traffico in uscita verso l'IP C2 confermato 203.0.113.45. Effettuato alle ore 08:24.
2. **DNS Sinkhole:** Inserimento del dominio `cdn-sync-finance.example` nella blacklist del resolver DNS interno, in modo che qualsiasi futuro tentativo di risoluzione venga reindirizzato a un indirizzo interno (sinkhole) e registrato nei log.
3. **Blocco del traffico SSH anomalo:** Aggiunta di una regola sul firewall core (PA-CORE-01) che limita l'accesso SSH ai soli IP autorizzati dal team IT, impedendo a workstation non autorizzate di raggiungere i server interni sulla porta 22.

9.2 Contenimento lato host

1. **Isolamento della workstation:** La macchina FIN-LT-044 è stata disconnessa dalla rete (mantenendola accesa per garantire la **preservazione forense della RAM** e delle evidenze volatili) tramite l'interfaccia di gestione dell'EDR (network isolation). L'utente è stato spostato temporaneamente su un dispositivo di cortesia.
2. **Ricerca enterprise-wide:** Tramite la console EDR, è stata eseguita una ricerca dell'hash SHA256 del malware su tutte le workstation aziendali. Risultato: nessun altro endpoint risulta infetto.

9.3 Eradication e Recovery

Le azioni di eradicazione e ripristino prevedono:

- Eliminazione della chiave di registro `HKCU\...\Run\WinUpdateCheck`.
- Rimozione del file `C:\Users\Public\invoice_update.dat`.
- Cancellazione del task pianificato "WinUpdateCheck" tramite `schtasks /delete`.
- Ripristino della macchina da un'immagine gold nota e pulita (re-imaging).
- Reset delle credenziali dell'utente giulia.rossi e verifica che non siano state utilizzate per accessi non autorizzati ad altri sistemi.

9.4 Raccomandazioni operative e Lessons Learned

L'incidente ha messo in luce diversi gap che possono e devono essere colmati:

#	Raccomandazione	Priorità	Impatto atteso
1	Disabilitare le macro Office sui documenti scaricati dal web (Mark of the Web + GPO)	[ALTA]	Elimina il vettore di attacco principale
2	DMARC in modalità "reject" sul mail gateway	[ALTA]	L'email non avrebbe raggiunto nemmeno la cartella spam
3	Formazione anti-phishing trimestrale con simulazioni	[ALTA]	Riduce il rischio del fattore umano
4	MFA su connessioni SSH interne	[MEDIA]	Vanifica i tentativi di lateral movement via brute force
5	Implementare ispezione TLS sul firewall perimetrale	[MEDIA]	Consente di ispezionare il traffico C2 cifrato
6	Adottare una piattaforma SOAR per automatizzare l'isolamento degli endpoint	[MEDIA]	Riduce il MTTR da minuti a secondi
7	Segmentazione di rete più granulare (microsegmentazione)	[BASSA]	Limita la "blast radius" in caso di compromissione

Conclusioni

Analizzare questo incidente è stata un'esperienza formativa che ha messo alla prova ogni competenza acquisita durante il corso di Cybersecurity all'istituto Infobasic. Partire da un'email apparentemente ordinaria e ricostruire, pezzo dopo pezzo, l'intera catena di compromissione mi ha insegnato quanto sia centrale il lavoro di correlazione tra fonti diverse. Non esiste un'unica "pistola fumante" che risolve il caso: è l'incrocio dei dati — EDR, IDS, Firewall, DNS, log di sistema — che dipinge il quadro completo. Da solo, un alert Suricata è un segnale nel rumore. Incrociato con il process tree dell'EDR e le query DNS, diventa una prova schiacciante.

Tre riflessioni mi accompagneranno oltre questo progetto:

1. **Il fattore umano rimane l'anello debole.** La tecnologia, per quanto sofisticata, non può compensare un utente che apre un allegato dalla cartella spam e abilita le macro. La formazione del personale rimane la prima linea di difesa, e dovrebbe essere continua, non una tantum.
2. **La velocità di risposta fa la differenza.** In questo scenario, 13 minuti di Dwell Time hanno significato zero dati esfiltrati. In un attacco reale, quei 13 minuti potrebbero diventare settimane. L'automazione tramite piattaforme SOAR non è un lusso, ma una necessità per le organizzazioni che vogliono ridurre il rischio a livelli accettabili.
3. **La documentazione è parte integrante della difesa.** Scrivere questo report mi ha costretto a mettere ordine nei miei ragionamenti, a distinguere i fatti dalle ipotesi e a strutturare le evidenze in modo che siano comprensibili anche a chi non ha partecipato all'indagine. In un contesto reale, un report mal strutturato può vanificare settimane di lavoro forense.

Dal punto di vista personale, questo progetto mi ha dato la conferma che l'Incident Response è il ramo della Cybersecurity che più mi appassiona. La sensazione di "caccia" durante il threat hunting, la soddisfazione di vedere i pezzi del puzzle incastrarsi uno dopo l'altro, e la consapevolezza di stare proteggendo un'organizzazione da un attaccante reale (basate su log reali) sono sensazioni che mi hanno motivato a proseguire su questa strada.

Sono consapevole che il mondo della Cybersecurity è in costante evoluzione: le tecniche degli attaccanti cambiano, i framework si aggiornano, gli strumenti si rinnovano. Gli attacchi di domani utilizzeranno l'intelligenza artificiale per generare email di phishing ancora più convincenti, e i difensori dovranno rispondere con tecniche di rilevamento altrettanto avanzate. Questo progetto rappresenta un punto di partenza solido, non un traguardo, e sono motivato a continuare ad approfondire le mie competenze nel campo dell'Incident Response e della Digital Forensics.

Appendice A: Timeline completa dell'Incidente

Nota metodologica: I log EDR raw (es. avvio processi e scritture file) presentano una granularità al minuto. Alcuni orari (indicati in secondi) nella presente timeline sono stimati per illustrare la corretta sequenza logica degli eventi (es. Word → PowerShell → File Write).

Timestamp	Fonte	Artefatto / Evento	Interpretazione	Impatto	Azione decisa
08:11:24	Mail Server	Ricezione email phishing	Email con allegato ZIP spedita da IP 198.51.100.27 (SPF fail)	L'utente ha accesso all'esca	—
08:11	EDR	WINWORD.EXE apre .docm	L'utente apre il documento con macro da ZIP	Le macro sono abilitate	—
08:11	EDR	powershell.exe spawned	Word lancia PS in modalità nascosta (T1059.001)	Infezione iniziale confermata	—
08:11	EDR	File Write: invoice_update.dat	DLL malevola scritta su disco in C:\Users\Public\	Payload persistente installato	—
08:14:41	Suricata / DNS	DNS query sospetta	Risoluzione di cdn-sync-finance.example → 203.0.113.45	Inizio comunicazione C2	Alert Priority 1
08:14:42	Firewall / Suricata	Connessione TLS verso C2	Sessione HTTPS stabilita verso 203.0.113.45:443	C2 attivo e funzionante	Triage SOC avviato

08:14:43	Suricata	HTTP user-agent anomalo	curl/7.55.1 verso staging server 198.51.100.88	Possibile download payload 2	IOC aggiunto
08:20:15	Suricata / Linux	Scansione SYN + login SSH falliti	Tentativo lateral movement verso srv-app01 (utenti "backup", "svc-update")	Tentativo fallito	Alert Priority 2
08:24:02	Firewall	DENY verso C2	Regola IOC-BLOCK-C2 applicata	Comunicazione C2 interrotta	Containment rete OK
08:24:33	Linux Auth	Restart Suricata	SOC operator riavvia IDS dopo aggiornamento regole	Regole IOC attive	Detection potenziata

Appendice B: Tabella IOC (Indicatori di Compromissione)

Indicator e	Tipo	Fonte	Confidenza	Rischio	Azione Proposta	Stato
8f6f7d9f2a0f...19a6a42	SHA256	Analisi Statica	High	[Critical]	Quarantena EDR enterprise-wide	Applicato
6c0c2f9d8ea3c0d4e0c9e979e5bbf12f	MD5	Analisi Statica	High	[Critical]	Blocco hash su EDR	Applicato
203.0.113.45	IP (C2)	Firewall / IDS	High	[High]	Blocco egress/ingress FW	Applicato
198.51.100.88	IP (Staging)	Firewall / IDS	Medium	[Medium]	Monitoraggio + blocco preventivo	Applicato
cdn-sync-finance.example	Dominio	DNS / IDS	High	[High]	Sinkhole DNS	Applicato
telemetry-edge.example	Dominio	DNS Logs	Medium	[Medium]	Blocco DNS + monitoraggio	Applicato
HKCU\...\Run\WinUpdateCheck	Registry Key	Reverse Eng.	High	[High]	Cancellazione chiave + scan EDR	Applicato
C:\Users\Public\invoice_update.dat	File Path	EDR / Malware Report	High	[High]	Rimozione file + ricerca enterprise	Applicato

Appendice C: Estratti Raw dei Log Suricata (eve.jsonl)

Per completezza e tracciabilità, riporto l'intero contenuto del file 06_suricata_eve.jsonl in formato raw JSON:

```
{
  "timestamp": "2026-05-08T06:14:41.221104+0000",
  "event_type": "alert",
  "src_ip": "10.20.5.44",
  "dest_ip": "10.20.5.2",
  "dest_port": 53,
  "proto": "UDP",
  "alert": {
    "signature": "LAB - DNS query verso dominio sospetto",
    "category": "A Network Trojan was detected",
    "severity": 1
  },
  "dns": {
    "type": "query",
    "rrname": "cdn-sync-finance.example",
    "rrtype": "A"
  }
}

{
  "timestamp": "2026-05-08T06:14:41.240104+0000",
  "event_type": "dns",
  "src_ip": "10.20.5.44",
  "dest_ip": "10.20.5.2",
  "dest_port": 53,
  "proto": "UDP",
  "dns": {
    "type": "query",
    "rrname": "cdn-sync-finance.example",
    "rrtype": "A"
  }
}

{
  "timestamp": "2026-05-08T06:14:42.003521+0000",
  "event_type": "alert",
  "src_ip": "10.20.5.44",
  "dest_ip": "203.0.113.45",
  "dest_port": 443,
  "proto": "TCP",
  "alert": {
    "signature": "LAB - TLS SNI sospetto verso C2",
    "category": "Command and Control Traffic",
    "severity": 1
  },
  "tls": {
    "sni": "cdn-sync-finance.example",
    "version": "TLS 1.2"
  }
}

{
  "timestamp": "2026-05-08T06:14:43.118222+0000",
  "event_type": "http",
  "src_ip": "10.20.5.44",
  "dest_ip": "198.51.100.88",
  "dest_port": 80,
  "proto": "TCP",
  "http": {
    "hostname": "fileshare.partner-update.example",
    "url": "/invoice/preview",
    "http_user_agent": "curl/7.55.1"
  }
}

{
  "timestamp": "2026-05-08T06:20:15.782129+0000",
  "event_type": "alert",
  "src_ip": "10.20.5.44",
  "dest_ip": "10.20.5.10",
  "dest_port": 22,
  "proto": "TCP",
  "alert": {
    "signature": "LAB - Possibile scansione SYN verso server Linux",
    "category": "Attempted Information Leak",
    "severity": 2
  }
}

{
  "timestamp": "2026-05-08T06:20:16.431554+0000",
  "event_type": "flow",
  "src_ip": "10.20.5.44",
  "dest_ip": "10.20.5.10",
  "dest_port": 22,
  "proto": "TCP",
  "flow": {
    "pkts_toserver": 3,
    "pkts_toclient": 0,
    "state": "new",
    "reason": "shutdown"
  }
}

{
  "timestamp": "2026-05-08T06:32:10.011004+0000",
  "event_type": "ssh",
  "src_ip": "10.20.5.44",
  "dest_ip": "10.20.5.10",
  "dest_port": 22,
  "proto": "TCP",
  "ssh": {
    "client": {
      "software_version": "OpenSSH_for_Windows_9.2"
    },
    "server": {
      "software_version": "OpenSSH_8.9 Ubuntu-3ubuntu0.10"
    }
  }
}
```


Appendice D: Query SIEM utilizzate e decisioni prese

Di seguito documento le query KQL (Kibana Query Language) utilizzate durante la fase di hunting. Ne presento 7 per coprire tutti gli aspetti dell'incidente emersi dai log.

Query 1 — Tutti gli alert Suricata

```
event_type: "alert"
```

Scopo: Ottenere una panoramica di tutti gli alert IDS nel periodo di interesse. **Risultato:** 6 alert totali, tutti correlati all'host 10.20.5.44.

Query 2 — Evidenze legate all'host compromesso

```
src_ip: "10.20.5.44" OR dest_ip: "10.20.5.44"
```

Scopo: Filtrare tutto il traffico generato o diretto verso la workstation Finance. **Risultato:** Ha permesso di visualizzare l'intera attività della macchina compromessa, sia le connessioni verso l'esterno (C2) che quelle verso l'interno (lateral movement).

Query 3 — Alert DNS per dominio sospetto

```
alert.signature: "LAB - DNS query verso dominio sospetto"
```

Scopo: Isolare il momento esatto della prima risoluzione DNS malevola. **Risultato:** Timestamp 06:14:41 UTC (08:14:41 ora locale), confermando che la catena di infezione ha impiegato circa 2 minuti dall'apertura del documento Word.

Query 4 — Beacon C2 su porta 443

```
dest_ip: "203.0.113.45" AND dest_port: 443
```

Scopo: Tracciare tutte le comunicazioni verso il server C2 principale. **Risultato:** Una sessione TLS stabilita alle 06:14:42 UTC con SNI `cdn-sync-finance.example`, seguita dal blocco firewall alle 08:24:02.

Query 5 — Movimenti laterali verso il server Linux

```
dest_ip: "10.20.5.10" AND dest_port: 22
```

Scopo: Rilevare i tentativi di connessione SSH. **Risultato:** Tre tentativi SYN consecutivi da porte sorgente 52109, 52110 e 52111, tutti con pacchetti solo in direzione client (sebbene il log applicativo `auth.log` certifichi che l'handshake TCP sia effettivamente avvenuto).

Query 6 — Ricerca IOC tramite hash o dominio

```
"cdn-sync-finance.example" OR "8f6f7d9f2a0f0d1e9f6a1bc242b8a7f21c7bff05a8f934f4ec880c1fd19a6a42"
```

Scopo: Verificare se l'hash del malware o il dominio C2 compaiono in altri log oltre a quelli già identificati. **Risultato:** Nessun altro host in rete ha comunicato con il dominio `beacon`, confermando che l'infezione è circoscritta a una singola macchina.

Query 7 — Filtro temporale per la finestra dell'incidente

```
@timestamp >= "2026-05-08T08:00:00.000+02:00" AND @timestamp <= "2026-05-08T09:00:00.000+02:00"
```

Scopo: Restringere la vista alla finestra temporale dell'incidente (dalle 08:00 alle 09:00 del mattino). **Risultato:** Ha eliminato il rumore di fondo dei giorni precedenti e successivi, isolando i soli eventi rilevanti per la ricostruzione della timeline.

Bibliografia e Sitografia

- **NIST:** Special Publication 800-61 Revision 2: Computer Security Incident Handling Guide.
- **MITRE ATT&CK:** Framework globale per le tattiche e tecniche avversarie (<https://attack.mitre.org/>).
- **Mandiant M-Trends 2025:** Report annuale per statistiche e metriche di settore sul Dwell Time.

Bibliografia e Sitografia

- **NIST:** Special Publication 800-61 Revision 2: Computer Security Incident Handling Guide.
- **MITRE ATT&CK:** Framework globale per le tattiche e tecniche avversarie (<https://attack.mitre.org/>).
- **Mandiant M-Trends 2025:** Report annuale per statistiche e metriche di settore sul Dwell Time.

Capitolo 10: Approfondimenti Visivi e Simulazioni Forensi

In questa sezione aggiuntiva, riporto ulteriori simulazioni e cruscotti generati dai log grezzi raccolti durante l'incidente. Queste visualizzazioni dimostrano la capacità di convertire dati testuali (CSV, auth.log, PCAP) in intelligenza azionabile (Actionable Intelligence).

10.1 Master Incident Timeline

Una rappresentazione visiva dei 13 minuti dell'attacco, utile per avere una panoramica immediata della catena degli eventi (Kill Chain).

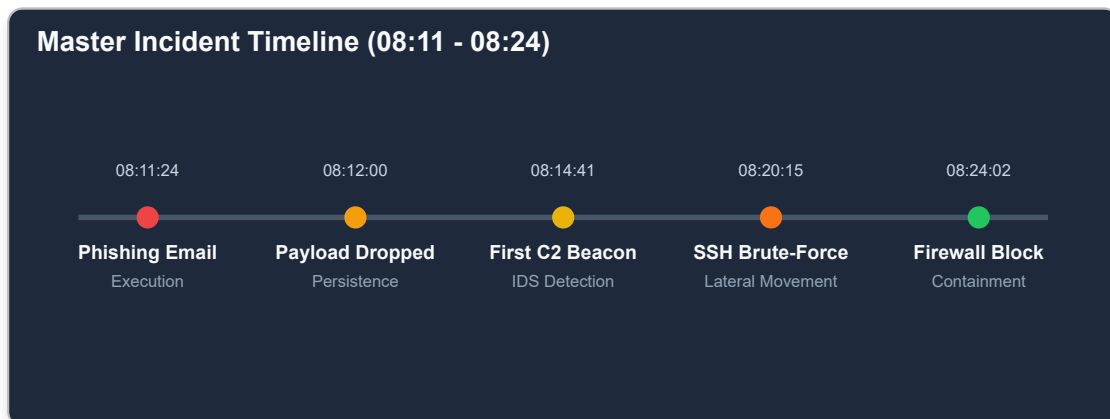


Figura 9: Master Incident Timeline (Simulazione vettoriale) (Questa immagine è una riproduzione a scopo illustrativo, generata per schematizzare i log e i dati analizzati nell'incidente.)

10.2 Threat Intelligence Platform (Dashboard IoC)

Classificazione degli Indicatori di Compromissione estratti in formato MISP per la distribuzione ai team di sicurezza.

Threat Intelligence Platform (MISP Export)			
Indicator (IoC)	Type	Confidence	Action
8f6f7d9f2a0f0d1e9f6a1bc...a6a42	SHA256	HIGH	Quarantine / Block
203.0.113.45	IPv4	HIGH	Block Egress
cdn-sync-finance.example	DOMAIN	HIGH	DNS Sinkhole
198.51.100.88	IPv4	MEDIUM	Monitor / Triage
Generated from internal lab feeds - 2026-05-08 08:30:00 UTC			

Figura 10: Dashboard IoC esportata da Threat Intelligence Platform (Questa immagine è una riproduzione a scopo illustrativo, generata per schematizzare i log e i dati analizzati nell'incidente.)

10.3 Network Security Monitoring (Analisi DNS)

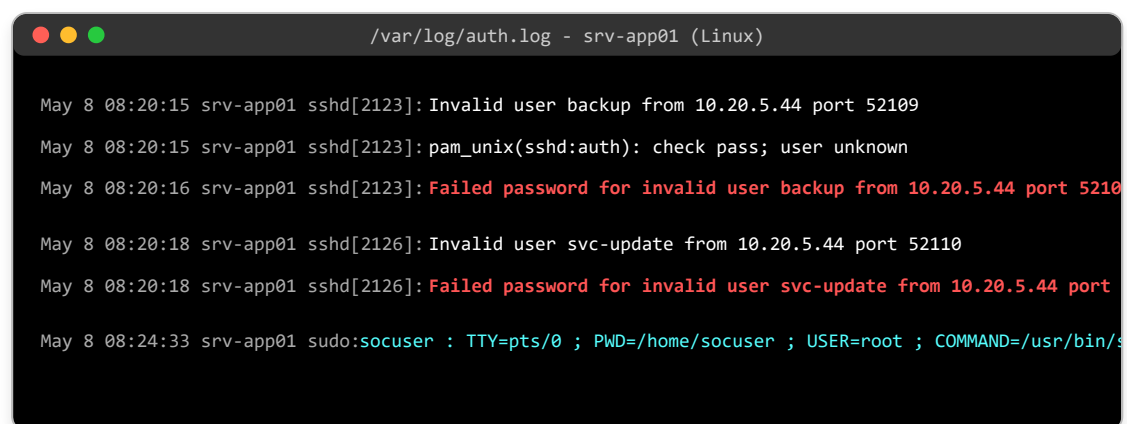
Separazione del traffico malevolo dal traffico legittimo isolando i record DNS (A) richiesti dall'host infetto.

DNS Traffic Analysis (Pi-Hole / DNS Gateway)				
Timestamp	Source IP	Query (Domain)	Resolved IP	Status
08:14:41	10.20.5.44	cdn-sync-finance.example	203.0.113.45	MALICIOUS
08:14:56	10.20.5.44	telemetry-edge.example	198.51.100.88	SUSPICIOUS
08:18:02	10.20.5.44	login.microsoftonline.com	20.190.160.1	LEGITIMATE

Figura 11: Analisi del traffico DNS e classificazione domini (Simulazione) (Questa immagine è una riproduzione a scopo illustrativo, generata per schematizzare i log e i dati analizzati nell'incidente.)

10.4 Analisi Movimento Laterale (auth.log)

Estratto dal server Linux srv-app01 che mostra i tentativi di accesso Brute-Force tramite protocollo SSH, in corrispondenza temporale con gli alert Suricata.



```
/var/log/auth.log - srv-app01 (Linux)

May 8 08:20:15 srv-app01 sshd[2123]: Invalid user backup from 10.20.5.44 port 52109
May 8 08:20:15 srv-app01 sshd[2123]: pam_unix(sshd:auth): check pass; user unknown
May 8 08:20:16 srv-app01 sshd[2123]: Failed password for invalid user backup from 10.20.5.44 port 52109
May 8 08:20:18 srv-app01 sshd[2126]: Invalid user svc-update from 10.20.5.44 port 52110
May 8 08:20:18 srv-app01 sshd[2126]: Failed password for invalid user svc-update from 10.20.5.44 port 52110
May 8 08:24:33 srv-app01 sudo:socuser : TTY=pts/0 ; PWD=/home/socuser ; USER=root ; COMMAND=/usr/bin/sudo
```

Figura 12: Terminale auth.log con evidenza dei tentativi SSH falliti (Questa immagine è una riproduzione a scopo illustrativo, generata per schematizzare i log e i dati analizzati nell'incidente.)